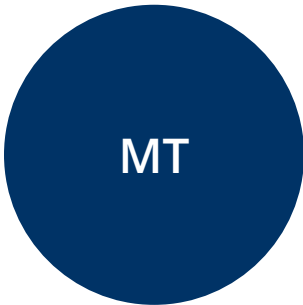




MT

SECURITY ASSESSMENT FINDINGS REPORT

MedTech Solutions | EMR & Cloud Infrastructure

CLIENT: MedTech Solutions

INDUSTRY: Healthcare Technology

ASSESSMENT PERIOD: May 15, 2024 – May 22, 2024

REPORT DATE: May 22, 2024

Prepared By: Solomon Mwaura

CyberSecure Consulting Group

1. Confidentiality & Disclaimer

This document contains proprietary and confidential information belonging to **MedTech Solutions** and **CyberSecure Consulting Group (CCG)**. Unauthorized duplication, disclosure, or distribution is strictly prohibited. Access is restricted to authorized personnel directly involved in the remediation or review of these findings.

Disclaimer: This penetration test represents a point-in-time assessment. Results reflect the security posture as evaluated during the engagement window and do not account for subsequent changes.

2. Assessment Overview

The purpose of this assessment was to evaluate the security posture of MedTech Solutions by identifying vulnerabilities, misconfigurations, and security weaknesses in their cloud-based electronic medical records (EMR) system, patient portal, and supporting cloud infrastructure.

Methodologies Used:

- **NIST SP 800-115:** Technical Guide to Information Security Testing.
- **OWASP Testing Guide:** Web application security assessment.
- **MITRE ATT&CK:** Mapping attacker tactics and techniques.

Assessment Phases:

Phase	Description
Planning	Define objectives and rules of engagement.

Phase	Description
Discovery	Reconnaissance, network scanning, and service enumeration.
Attack	Exploitation of vulnerabilities to determine real-world impact.
Reporting	Documentation of findings and remediation strategy.

3. Assessment Components

Assessment Type	Description	Tools Used
External Penetration Test	Evaluated public services, portals, and remote access.	Nmap, Metasploit, Hydra
Web Application Testing	SQL injection, auth flaws, and session management in EMR.	Burp Suite, OWASP ZAP, SQLmap
Cloud Security Review	AWS configurations, DB access, and API security.	CloudMapper, Nmap

4. Finding Severity Ratings

Severity	CVSS Score	Definition
CRITICAL	9.0 – 10.0	Immediate action required; high risk of system compromise.
HIGH	7.0 – 8.9	Serious security flaw; could lead to data breaches.
MEDIUM	4.0 – 6.9	Exploitable vulnerability; requires additional factors.
LOW	0.1 – 3.9	Minor security concern with limited potential.

5. Scope

In-Scope Assets:

- EMR Web App & Patient Portal
- AWS S3 Buckets (Storage)
- API Endpoints & DB Servers
- External Auth Services

Exclusions:

- DoS / DDoS Attacks
- Social Engineering (Phishing)

6. Executive Summary

Finding Totals: 2 Critical, 3 High, 4 Medium.

The assessment confirmed that insecure API authentication and weak database access controls could allow an unauthenticated attacker to retrieve and modify patient health records without authorization. These vulnerabilities pose severe risks to patient data confidentiality and HIPAA compliance.

Attack Path Summary

- 1 Reconnaissance:** Identified exposed API endpoints with no authentication.
Recommendation: Implement OAuth 2.0 / API keys.
- 2 Exploitation:** Used default DB credentials to gain unauthorized access to EMR records.
Recommendation: Rotate all default credentials immediately.
- 3 Injection:** Extracted DB contents via SQL injection in the EMR system.
Recommendation: Use parameterized queries & deploy a WAF.
- 4 Hijacking:** Intercepted weak session cookies to hijack active user sessions.
Recommendation: Enforce Secure/HttpOnly flags.
- 5 Data Leakage:** Accessed publicly exposed AWS S3 buckets with patient images.
Recommendation: Restrict S3 permissions & enable encryption.

Security Strengths

- **Network Segmentation:** Partial segmentation limited lateral movement.

- **Cloud Logging:** AWS CloudTrail enabled for audit trails.
- **Encryption:** Patient portal enforced HTTPS for all traffic.

7. Vulnerabilities by Impact

Vulnerability	Severity	Impact	Recommendation
Insecure API Auth	CRITICAL	Unauth access to patient records via open APIs.	Enforce OAuth 2.0 & API Gateway management.
Weak DB Access	CRITICAL	Full read/write access to EMR via default creds.	Rotate default creds; enforce least-privilege.
Session Hijacking	HIGH	Theft of session tokens to impersonate users.	Set Secure, HttpOnly, SameSite flags.
SQL Injection	HIGH	DB manipulation and potential exfiltration.	Use parameterized queries; deploy WAF.
Exposed S3 Bucket	HIGH	Patient images publicly accessible.	Restrict policies; disable public access.
Unpatched Server	MEDIUM	Exposed to known CVEs (Outdated Apache).	Apply latest patches; establish routine.
Missing Headers	MEDIUM	Risk of clickjacking & protocol downgrade.	Implement CSP, HSTS, X-Frame-Options.
Excessive IAM	MEDIUM	Increased blast radius for cloud accounts.	Enforce least-privilege; regular reviews.
Exposed Debug Mode	MEDIUM	Leaking logs and config details.	Disable debug mode in production.

8. Conclusion & Next Steps

MedTech Solutions must immediately prioritize the remediation of **Critical** and **High** severity vulnerabilities. The unauthenticated API endpoints and default database credentials present the most direct path to unauthorized access to Protected Health Information (PHI).

Recommended Roadmap:

- **Immediate (7-14 Days):** Fix all Critical and High findings.
- **Short-Term (30-60 Days):** Address Medium-severity findings in a structured cycle.
- **Training:** Developer training on secure coding and credential hygiene.
- **Compliance:** HIPAA compliance review to assess regulatory impact.
- **Monitoring:** Enhanced logging and continuous cloud threat detection.
- **Assessment:** Schedule semi-annual penetration tests.

Report Finalized by Solomon Mwaura
CyberSecure Consulting Group